

Sub-processor Schedule — Device Attestation Provider

This schedule governs processing carried out by device attestation providers — **Apple App Attest** and **Google Play Integrity** — in connection with the shyware write-only posture and coercion-resistance guarantee. It is incorporated by reference into the Shyware Data Processing Agreement and is published at <https://shyware.fyi/legal/privacy/dpia/dpa/schedule-attestation>.

Configuration trigger: This schedule applies when `deployment.runtime_fallbacks.write_only_on_missing` or `write_only_on_untrusted_device_attestation` is set to `true` in shyconfig, which is the default for all non-demo deployments. It applies to Android deployments (Play Integrity API) and iOS deployments (App Attest / DCAppAttestService).

Role in the Protocol

Device attestation providers are **runtime trust signal providers**, not data authorities in the two-list protocol sense. They occupy a structurally distinct position from the four canonical authorities (Auth, IDV/KYC, Eligibility, Reconciling):

- **Not a data authority:** Attestation providers do not write to or read from the canonical List 1 / List 2 ledger. They do not hold the off-chain linkage store. They cannot initiate or co-sign rescissions.
- **Pre-submission posture gate:** The attestation verdict gates whether the submission receives receipt confirmation (recoverable posture) or proceeds as write-only (no receipt). It does not gate whether the submission enters canonical state — the two-list write proceeds regardless.
- **Closest analogy:** A TLS certificate authority. The attestation provider certifies the integrity of the execution environment, not the content of the submission.

The Mainhub patent makes device attestation a co-launch requirement for all deployments requiring recovery or coercion resistance: *“Browser-based deployments are structurally write-only and cannot satisfy non-write-only assurance. The protocol’s architecture is thus mobile-first and attestation-dependent for all deployments requiring recovery or coercion resistance”* (composition.tex, l. 1635).

Role Definition

Provider	Role
Google Play Integrity API	Issues signed integrity verdicts for Android apps; verifies app identity, installation source, and device health
Apple App Attest (DCAppAttestService)	Issues FIDO2-based attestation assertions for iOS apps; verifies app and device integrity

Data Processed by Attestation Providers

Neither provider receives submission content, identity hashes, ballot direction, or any shyware canonical-state data. The data flow is:

- **Google Play Integrity:** The app calls `IntegrityTokenProvider.requestIntegrityToken(nonce)`. Google receives: app package name, signing certificate hash, Play Store installation status, device model and Android version, Play Services version, and the operator-supplied nonce. Google returns a signed JWT containing the integrity verdict. Google does not receive user identity, submission content, or any shyware protocol data.
- **Apple App Attest:** The app calls `DCAppAttestService.attestKey(_ :clientDataHash:)`. Apple receives: app bundle ID, team ID, device-bound key material (FIDO2 attestation), and a client data hash (SHA-256 of server-supplied challenge). Apple returns an attestation object. Apple does not receive user identity, submission content, or any shyware protocol data.

Personal Data Processed

The attestation providers process the following data that may constitute personal data:

Data element	Characterisation	Legal basis
Network IP address (implicit in API call)	Personal data where linkable to natural person	Art. 6(1)(f) legitimate interest (app integrity verification); note EDPB guidance on IP addresses
Device model and OS version	Pseudonymous device identifier component	Art. 6(1)(f) legitimate interest (fraud/abuse prevention)
App package name / bundle ID	Not personal data on its own; operator data	Not personal data
Integrity verdict (MEETS_DEVICE_INTEGRITY etc.)	Not personal data on its own; may be used to infer device quality	Art. 6(1)(f) legitimate interest

The IP address is the primary personal data element. In EU deployments, the network call to Google’s or Apple’s attestation APIs may constitute a transfer of personal data to a third country. Operators must confirm SCCs or adequacy for these transfers.

Structural Constraints

- **Not part of the two-list invariant:** The attestation verdict is a runtime input to the shyware SDK’s posture determination logic. It does not appear in List 1 or List 2 of the canonical ledger. It is not written to the off-chain linkage store.

- **Posture gate only:** A failed attestation triggers write-only fallback posture. The submission still enters canonical state; only receipt confirmation is suppressed.
- **No canonical data access:** Attestation providers cannot query or modify canonical ledger state.
- **No identity linkage:** Attestation providers do not receive the user’s identity, the sub claim, or the identity hash derived for List 2. The nonce / client data hash passed to the attestation API is not derived from user identity.
- **No submission linkage:** The attestation call is made before the submission transaction is constructed. The attestation token does not encode submission direction, payload, or scoping ID.
- **Coercion resistance preserved:** Even if an attestation provider were compromised or compelled to produce false verdicts, canonical state non-derivability is preserved — the attestation verdict is an input to posture, not to the two-list write or the rejection predicate.

Operator Obligations

- Register the app with Google Play Integrity API and Apple App Attest before production deployment.
- Include the attestation provider data flow in the operator’s privacy notice and Records of Processing under Art. 30.
- Confirm SCCs or adequacy decision for EU personal data transferred to Google (US) and Apple (US) via attestation API calls.
- Do not pass user identity, sub claim, submission content, or scoping ID as the nonce / client data hash to the attestation API. Use a server-generated random challenge only.
- Implement the `write_only_on_missing_play_integrity` and `write_only_on_untrusted_device_attes` fallback flags as specified in shyconfig for all production deployments requiring coercion resistance.
- Review Google’s and Apple’s DPAs and privacy policies for the attestation APIs before production.

SEDA_HAQQ / Hostile-Regime Note

In hostile-regime deployments (shyvoting-v1 with `default_posture: coercion_resistant`), device attestation is the structural foundation of the coercion-resistance guarantee: after submission, the attested device retains only the direction-free submission ID and suppresses all receipt data. A coercer seizing the device gets no evidence of submission direction. This property depends on both the attestation verdict (confirming the execution environment is uncompromised) and the write-only posture enforcement in the shyware SDK. The attestation provider’s role

is necessary but not sufficient — the SDK must also implement readback suppression and the device OS must enforce the App Attest / Play Integrity sandbox boundary.

This schedule is incorporated by reference into the Shyware Data Processing Agreement and is published at <https://shyware.fyi/legal/privacy/dpia/dpa/schedule-attestation>.